Introduction to Information Security

Class 1 Notes: Cyber Concepts, CIA Triad, Threats, Cyber Dimensions and ICT Indices

Course outline covered in this class: Introduction to information security, cyber threats and attacks, operating system and network security, cyber forensics, and cyber ethics. This class focuses on the introduction, the five dimensions of cybersecurity, and ICT indices.

1. Cybersecurity: Basic Concepts

Cybersecurity is the practice of defending computers, servers, mobile devices, electronic systems, networks, and data from malicious attacks. It is the application of technologies, processes, and controls to protect systems, networks, programs, devices and data. It covers every aspect of protecting an organization, its employees, and its assets against cyber threats.

Cyber is a combining form meaning "computer", "computer network", or "virtual reality". It refers to things involving computers or computer networks, such as the Internet.

Cyberspace is an intricate environment of interactions among people, software, and services. It is maintained by the worldwide distribution of ICT devices and networks. Today it is a common pool used by citizens, businesses, critical information infrastructure, the military, and governments, which makes it hard to draw clear boundaries between these groups.

2. The CIA Triad

The three letters stand for **Confidentiality, Integrity, and Availability**. The CIA triad is the common model that forms the basis for developing security systems. It is used for finding vulnerabilities and methods for creating solutions.

Principle	Meaning	Standard Measures
Confidentiality	Only authorized people can access information.	Data encryption, two-factor authentication, biometric verification, security tokens.
Integrity	Data stays accurate, complete, and unaltered.	Cryptography, checksums, file permissions, uninterrupted power supplies, data backups.
Availability	Systems and data are accessible when needed.	Backups to external drives, firewalls, backup power supplies, data redundancy.

3. Assets

An **asset** is any data, device, or other component of an organization's systems that is valuable, often because it contains sensitive data.

- **Examples:** an employee's desktop, laptop, or company phone, and the applications on them; critical infrastructure such as servers and support systems.
- **Information assets** are the most common assets in an organization. These are databases and physical files, meaning the sensitive data the organization stores.

4. Threats, Attacks and Risk

Cyber threat: Any incident that could negatively affect an asset, for example if it is lost, knocked offline, or accessed by an unauthorized party. Threats are acts by individuals with harmful intent, whose goal is to steal data or disrupt computing systems. They compromise confidentiality, integrity, or availability.

- **Intentional threats:** criminal hacking, a malicious insider stealing information.
- **Accidental threats:** employee error, technical malfunction, or an event causing physical damage such as fire or natural disaster.

Cyber attack: An offensive action by a malicious actor intended to undermine networked computers and their resources, including unauthorized access, unapproved changes, and malicious destruction. Examples are DDoS and man-in-the-middle (MITM) attacks.

Cyber risk: The estimated probability of potential losses that may result from a threat.

Term	What it means	Example
Cyber attack	The offensive action itself.	A botnet launches a DDoS attack on a website.
Cyber threat	The possibility that a particular attack may occur.	Enterprises with online retail sites face the threat of a DDoS attack.
Cyber risk	The probability of potential losses linked to the threat.	Lost revenue from downtime multiplied by the probability of the attack.

5. Common Sources of Cyber Threats Against Organizations

- **Nation states:** hostile countries attack local companies and institutions to interfere with communications, cause disorder, and inflict damage.
- **Terrorist organizations:** they attack or abuse critical infrastructure, threaten national security, disrupt economies, and cause bodily harm to citizens.
- **Criminal groups:** organized hackers seeking economic benefit through phishing, spam, spyware, malware, extortion, theft of private information, and online scams.
- **Hackers:** individuals motivated by personal gain, revenge, financial gain, or political activity. They often develop new threats to advance their ability and standing in the hacker community.
- **Malicious insiders:** employees, contractors, suppliers, or partners with legitimate access who abuse their privileges. Outsiders who compromise a privileged account and impersonate its owner also fall in this group.

6. Types of Cybersecurity Threats

#	Threat type
1	Malware attacks
2	Social engineering attacks
3	Supply chain attacks
4	Man-in-the-middle (MITM) attacks
5	Denial-of-service (DoS / DDoS) attacks
6	Injection attacks

7. Types of Cyber Security Solutions

- **Application security:** tests software for vulnerabilities during development and protects running applications from network attacks, software exploits, and web application attacks.
- **Network security:** monitors network traffic, identifies malicious traffic, and lets organizations block, filter, or mitigate threats.
- **Cloud security:** implements controls in public, private, and hybrid clouds, detecting and fixing misconfigurations and vulnerabilities.

- **Endpoint security:** deployed on servers and employee workstations to prevent malware, unauthorized access, and exploitation of OS and browser vulnerabilities.
- **IoT security:** connected devices often store sensitive data but are usually not protected by design; these solutions add visibility and protection.
- **Threat intelligence:** combines feeds about attack signatures and threat actors to help teams detect attacks, understand them, and design responses.

8. Information Security Fields

Physical cybersecurity (biometric authentication, surveillance cameras, access control); information, endpoint and application security; IT auditing, consulting, governance, risk and compliance (GRC); ethical hacking and penetration testing; intrusion detection; threat intelligence; software development; cloud security; digital forensics and incident response; and cryptography.

9. Dimensions of Cybersecurity

The **Cybersecurity Capacity Maturity Model (CMM) for Nations** is a methodical framework for reviewing a country's cybersecurity capacity. It treats cybersecurity as five dimensions which, together, make up the national capacity a country needs to deliver cybersecurity effectively.

Dimension	Name	Focus
Dimension 1	Cybersecurity Policy and Strategy	Effective policy and strategy
Dimension 2	Cybersecurity Culture and Society	Effective trust, confidence and mindset
Dimension 3	Building Cybersecurity Knowledge and Capabilities	Effective security education, awareness and technical expertise
Dimension 4	Legal and Regulatory Frameworks	Effective legal regime
Dimension 5	Standards and Technologies	Effective implementation of standards, infrastructure, technology and good practices

Dimension 1: Cybersecurity Policy and Strategy

- **D1.1 National Cybersecurity Strategy:** strategy development, content, implementation and review, international engagement.
- **D1.2 Incident Response and Crisis Management:** identification and categorization of incidents, organization, integration of cybersecurity into national crisis management.
- **D1.3 Critical Infrastructure (CI) Protection:** identification, regulatory requirements, operational practice.
- **D1.4 Cybersecurity in Defence and National Security:** defence force cybersecurity strategy and capability, civil defence coordination.

Dimension 2: Cybersecurity Culture and Society

- **D2.1 Cybersecurity Mindset:** awareness of risks, priority of security, practices.
- **D2.2 Trust and Confidence in Online Services:** digital literacy and skills, user trust in online search and information, e-commerce and e-government services, disinformation.
- **D2.3 User Understanding of Personal Information Protection Online.**
- **D2.4 Reporting Mechanisms.**
- **D2.5 Media and Online Platforms:** media and social media.

Dimension 3: Building Cybersecurity Knowledge and Capabilities

- **D3.1 Building Cybersecurity Awareness:** initiatives by government, private sector and civil society; executive awareness raising.

- **D3.2 Cybersecurity Education:** provision and administration.
- **D3.3 Cybersecurity Professional Training:** provision and uptake.
- **D3.4 Cybersecurity Research and Innovation:** research and development.

Dimension 4: Legal and Regulatory Frameworks

- **D4.1 Legal and Regulatory Provisions:** legal and regulatory requirements for cybersecurity, substantive and procedural cybercrime legislation, human rights impact assessment.
- **D4.2 Related Legislative Frameworks:** data protection legislation, child protection online, consumer protection, intellectual property.
- **D4.3 Legal and Regulatory Capability and Capacity:** regulatory bodies, law enforcement, prosecution, courts.
- **D4.4 Formal and Informal Cooperation Frameworks to Combat Cybercrime:** government and criminal justice collaboration, law enforcement cooperation with the private sector, and cooperation with foreign law enforcement counterparts.

Dimension 5: Standards and Technologies

- **D5.1 Adherence to Standards:** ICT security standards, standards in procurement, standards for provision of products and services.
- **D5.2 Security Controls:** technological security controls, cryptographic controls.
- **D5.3 Software Quality:** software quality and assurance.
- **D5.4 Communications and Internet Infrastructure Resilience:** internet infrastructure reliability, monitoring and response.
- **D5.5 Cybersecurity Marketplace:** cybersecurity technologies, services and expertise, security implications of outsourcing, cyber insurance.
- **D5.6 Responsible Disclosure:** sharing vulnerability information, processes and legislation for responsible disclosure of security flaws.

> **Key point:** The five dimensions are interconnected. The official diagram shows links between all of them, so a strong national cybersecurity posture depends on all five working together.

10. ICT Indices

ICT indices are standard composite measures of the development, deployment and use of ICT. They combine relevant parameters, and they allow countries to be compared over time. They use quantitative data on ICT access, use and skills, which helps governments and organizations set targeted policies for digital inclusion and economic growth.

Purpose and Importance

- **Monitoring progress:** tracking ICT development within and between countries.
- **Identifying gaps:** highlighting the extent of the digital divide.
- **Informing policy:** guiding strategies for digital inclusion and for using ICT in economic and social development.

The Five Major ICT Indices

Index	Introduced by	What it measures	Components	Bangladesh
Networked Readiness Index (NRI)	World Economic Forum (WEF)	Impact of ICT on the competitiveness of nations	Environment for ICT (market, political and regulatory, infrastructure); stakeholders (individuals, businesses, government); usage of ICT	2024: score 43.56, 89th of 133 countries

Index	Introduced by	What it measures	Components	Bangladesh
ICT Development Index (IDI)	International Telecommunication Union (ITU)	Benchmarks indicators of the information society	11 indicators in 3 categories: ICT readiness (infrastructure, access), ICT use (intensity), ICT capability (skills)	2025 IDI score 64.9 (2023 data). Global average 78; lower-middle-income average 66
E-Government Development Index (EGDI)	United Nations	How governments use ICT to deliver services and enable citizen participation	Online services, technological infrastructure, human capital	2024: 100th of 193 countries, score 0.6570
Global Cybersecurity Index (GCI)	International Telecommunication Union (ITU)	Commitment to cybersecurity across five pillars	Legal, technical, organizational, capacity development, cooperation measures	2024: 53rd of 194 countries
National Cyber Security Index (NCSI)	NCSI Project Team, e-Governance Academy Foundation, Estonia	Preparedness to prevent cyber threats and manage incidents	Legislation in force; established units; cooperation formats; outcomes (policies, exercises, technologies, websites, programs)	48th position, score 66.67 (2021 data)

The NCSI is also a publicly available database of evidence materials and a tool for national cybersecurity capacity building.

11. Quick Revision Points

- CIA triad: Confidentiality, Integrity, Availability. Learn the measures for each.
- Threat is the possibility, attack is the action, and risk is the expected loss.
- Five threat sources: nation states, terrorist organizations, criminal groups, hackers, malicious insiders.
- Five CMM dimensions, each with numbered sub-dimensions (D1.1 to D5.6).
- Know the introducer and components of each index: NRI has 3 components, IDI has 11 indicators in 3 categories, EGDI has 3 components, GCI has 5 pillars, NCSI has 4 aspects.
- Bangladesh rankings: NRI 89th (2024), EGDI 100th (2024), GCI 53rd (2024), NCSI 48th (2021).

> **Verify before the exam:** The Bangladesh NRI score appears in the slides as "43,56", which is read here as 43.56. Index scores and rankings are updated regularly, so confirm figures against the original reports.

Vulnerability, Threat and Risk

Class 2 Notes: Assets, Vulnerabilities, CVE and CVSS, Threats, Attack Vectors, Attack Surface, Risk

Core idea of this class: Threats are possible dangers, vulnerabilities are the flaws that can be used against you, and risks are the possible outcomes when an exploit happens. Learn the difference, because exams often ask you to classify a scenario as an asset, vulnerability, threat, or risk.

1. Assets

An **asset** is a resource owned or controlled by a person or business that is expected to provide a future benefit or generate income. Put simply, an asset is anything of value that the business wants to protect. This can include people, information or data, intellectual property, and physical property. **Cyber assets** are all the digital and physical resources an organization uses that require cybersecurity protection.

Key Characteristics of an Asset

- **Ownership or control:** the person or business owns or controls the asset.
- **Future benefit:** it is expected to provide economic benefit, such as cash flow, reduced expenses, or increased sales.
- **Tangible or intangible:** physical (buildings, machinery) or non-physical (patents, trademarks).

Examples of Cyber Assets

Category	Examples
Hardware	Servers, computers, network devices, endpoint devices
Software	Operating systems, applications, software libraries, code repositories
Data	Databases, documents, user credentials, sensitive information
Network	Network infrastructure, cloud services, APIs
Other	Identities (users and accounts), devices, cloud configurations

2. Vulnerability

A **vulnerability** is a weakness or defect in the design, implementation, integration, operation, or utilization of an asset. It is a flaw in a system (infrastructure, database, or software), but it can also exist in a process, a set of controls, or the way something has been deployed. Identifying vulnerabilities answers the question: *"How could harm occur?"*

CISA definition: The Cybersecurity and Infrastructure Security Agency defines a vulnerability as *"a set of conditions that may lead to an implicit or explicit failure of the confidentiality, integrity, or availability of an information system."*

Examples

- **Car:** leaving the car unlocked in a public parking lot. This does not guarantee harm, but it is an opening for someone.
- **Software and systems:** outdated software, unpatched software, weak passwords, misconfigured network settings, misconfigured firewalls, and human errors such as falling for phishing.

Types of Vulnerability (by location or origin)

- **Network:** flaws in the network's hardware or software.
- **Operating system:** an OS designed so every program or user has full access lets viruses and malware change things on behalf of the administrator.
- **Process:** specific process control weaknesses can cause vulnerabilities.
- **Physical:** unprotected hardware, stolen devices, or unauthorized access to servers.
- **Software failures:** bugs that are not found or fixed during development. Inadequate design and implementation enable unauthorized access, privilege escalation, and lateral movement.
- **Hardware failures:** design flaws in processors, firmware bugs, and insecure configurations. These are hard to fix because they often need physical replacement.
- **Human factors:** insufficient training, unmapped faulty processes, lack of awareness, misconfigurations, excessive permissions, and unnecessary services.

Technical vs. Human Vulnerabilities

- **Technical:** bugs in code or errors in hardware or software. According to Positive Technologies, in 2022, 72% of vulnerabilities were related to flaws in web application code.
- **Human:** employees falling for phishing, smishing (phishing via text messages), quishing, or similar attacks. The goal of 85% of these attacks is data theft.

Why Software Vulnerabilities Matter

When a process reads input from an attacker, it may be exploited if it contains vulnerabilities. A successful exploit can:

Effect of exploit	Security property compromised
Crash programs	Availability
Execute arbitrary code	Integrity
Obtain sensitive information	Confidentiality
Run with the privileges of other users	Violates the desired access control policy

Vulnerabilities vs. Exposures

- **Vulnerability:** a flaw in software code that attackers use to access a system and carry out unauthorized actions while posing as a legitimate user. They can execute code, access memory, install malware, and steal, delete, or alter data.
- **Exposure:** a mistake in software code or configuration that gives an attacker access to a system or network. Data breaches, leaks, and sales of personally identifiable information (PII) on the dark web can result.

3. Common Vulnerabilities and Exposures (CVE)

CVE is a reference system that catalogs publicly known security threats. It provides a free dictionary of software and firmware vulnerabilities so organizations can improve their defenses. The CVE list is maintained by the **MITRE Corporation**, a nonprofit that runs federally sponsored R&D centers, and the slides state that CVE is sponsored by the U.S. Department of Homeland Security's National Cyber Security Division (NCSD).

> **Note on the name:** the slides call CVE both "Common Vulnerabilities and Exposures" and "Common Vulnerability Enumeration." Both forms appear in the sources. Use "Common Vulnerabilities and Exposures" in exams unless told otherwise.

4. Common Vulnerability Scoring System (CVSS)

CVSS is a widely used framework for rating the severity of software vulnerabilities. It gives a numerical score from **0 to 10** that represents the potential impact of a vulnerability, which helps organizations decide what to fix first.

- **Severity assessment:** shows how dangerous a vulnerability is.
- **Prioritization:** decides which vulnerabilities to address first, based on severity.
- **Communication:** gives teams and organizations a standard way to describe severity.

Qualitative Severity Ratings

Severity	CVSS v2.0 range	CVSS v3.x range	CVSS v4.0 range
None	-	0.0	0.0
Low	0.0 to 3.9	0.1 to 3.9	0.1 to 3.9
Medium	4.0 to 6.9	4.0 to 6.9	4.0 to 6.9
High	7.0 to 10.0	7.0 to 8.9	7.0 to 8.9
Critical	-	9.0 to 10.0	9.0 to 10.0

> **Exam tip:** v2.0 has no "Critical" band; its top band (7.0 to 10.0) is High. v3.x and v4.0 split it into High (7.0 to 8.9) and Critical (9.0 to 10.0).

CVSS and CVE: The Relationship

- **CVE** identifies and catalogs each vulnerability with a unique ID, so it is easy to track.
- **CVSS** gives that vulnerability a severity score.
- The **National Vulnerability Database (NVD)** provides CVSS scores for CVE records.
- Example: the Heartbleed vulnerability (**CVE-2014-0160**) has a CVSS score of **7.5**, which indicates high severity.

How to Assess Vulnerability

- Evaluate the effectiveness of existing security measures and controls.
- Assess the strength of security systems, access controls, and training programs.
- Identify vulnerabilities found through assessments or audits.
- Score them with a CVSS calculator, which rates severity from numerical metrics about impact and exploitability.

5. Threat

A **threat** is any potential danger or harmful event that can exploit a vulnerability and cause harm to a system, organization, or individual. A cyber threat is a malicious act that seeks to steal or damage data, or disrupt a digital network or system. Identifying threats answers the question: *"Who or what could cause harm?"*

Worked Example: House and Car

- **House:** the house and its contents are **assets**. A front door left unlocked or with broken locks is a **vulnerability**. A burglar who knows about the broken locks and plans to use them is a **threat**. The likelihood of the burglar entering and stealing jewelry or electronics is the **risk**.
- **Car:** the car is an **asset**. A door left unlocked is a **vulnerability**. A carjacker who takes the opportunity is a **threat** that is human-made and deliberate. A car window left down with coins in the cupholder is another vulnerability, a passerby who notices is a threat, and the value of the coins is the risk.

Types of Threat

Type	Description	Examples
Intentional	Deliberate, human-made threats	Malware, phishing, illegally accessing someone's account
Unintentional	Accidental human errors	Forgetting to update the firewall or antivirus

Type	Description	Examples
Natural	Caused by natural disasters	Floods, fires, earthquakes, lightning, hurricanes

Threats can be natural or human-made, and accidental or deliberate.

Common Sources of Cyber Threats Against Organizations

- **Nation states:** hostile countries attack local companies and institutions to interfere with communications, cause disorder, and inflict damage.
- **Terrorist organizations:** they destroy or abuse critical infrastructure, threaten national security, disrupt economies, and harm citizens.
- **Criminal groups:** organized hackers seeking economic benefit through phishing, spam, spyware, malware, extortion, theft of private information, and online scams.
- **Hackers:** individuals motivated by personal gain, revenge, financial gain, or politics. They often develop new threats to build their reputation in the hacker community.
- **Malicious insiders:** employees, contractors, suppliers, or partners with legitimate access who abuse their privileges. Outsiders who compromise a privileged account and impersonate its owner also count.

Common Threat Categories Facing Modern Organizations

- **Adversarial threats:** third-party vendors, insiders, hacker collectives, corporate espionage, nation states, and the malware they create. Large organizations counter these with a Security Operations Center (SOC) and trained staff.
- **Natural disasters:** hurricanes, floods, earthquakes, fire, and lightning can destroy data and services. Reduce the risk by spreading operations across multiple sites or using distributed cloud resources.
- **System failure:** can cause data loss and business disruption. Run critical systems on quality equipment, add redundancy, back them up, and choose providers with timely support.
- **Human error:** accidentally downloading malware, being tricked by social engineering, or misconfiguring storage that exposes sensitive data. Reduce it with employee training, strong controls, password managers, and misconfiguration monitoring.

Some Common Cyber Threats

Common cyber threats		
Malware	Man-in-the-Middle (MitM) attacks	DNS spoofing
Phishing	SQL injection	Brute force attacks
DoS / DDoS attacks	Insider threats	Trojan horses
Ransomware	Zero-day exploits	Data breaches

6. Attack Vectors and Attack Surface

Term	Definition	Example
Attack vector	A path or method cybercriminals use to gain unauthorized access to a system, network, or application.	An attacker exploits unpatched software to compromise a system, or deploys malware to infect it.
Attack surface	The sum of all attack vectors on a digital surface. It is the aggregate of exploitable points in a network.	Open ports, web applications, network devices, user accounts, physical access points.

> **Difference:** an attack vector is the specific route or tool an attacker uses. The attack surface is the overall set of points that could be targeted. Each vector leads into the attack surface.

Types of Attack Vectors

Category	Methods
Malware attacks	Viruses, worms, trojans, ransomware, cryptojacking, spyware, adware, fileless malware, rootkits
Social engineering	Baiting, pretexting, phishing, vishing (voice phishing), smishing, piggybacking, tailgating
Man-in-the-middle	Wi-Fi eavesdropping, email hijacking, DNS spoofing, IP spoofing, HTTPS spoofing
Denial of service	HTTP flood DDoS, SYN flood DDoS, UDP flood DDoS, ICMP flood, NTP amplification
Injection	SQL injection, code injection, OS command injection, LDAP injection, XML External Entities (XXE), Cross-Site Scripting (XSS)

Attack Surface Components

Category	Examples
Network insecurities	Open ports, weak protocols
Software bugs	Insufficiently secured in-house applications; vulnerable commercial programs (e.g., WordPress)
Physical security loopholes	Rogue or dissatisfied current and former employees; login credentials openly displayed (e.g., on sticky notes)
Social engineering-prone people	Reused or recycled passwords; unmonitored use of social media; unprotected personal devices

Social Engineering Attack Vectors

- **Phishing:** deceptive emails or messages that steal information or gain access.
- **Pretexting:** fabricated scenarios used to steal information.
- **Baiting:** enticing victims with offers or rewards so they click links or take other unsafe actions.
- **Tailgating:** following someone into a restricted area.

7. Risk and Cybersecurity Risk

Risk is the potential for loss or damage when a threat happens. It is the chance that a threat will exploit a vulnerability in an asset and cause a specific impact.

Types of Risk by Attacker Position

- **External:** risks from outside the organization, such as cyberattacks, phishing, ransomware, and DDoS attacks.
- **Internal:** risks from insiders who may have malicious intent or who are not properly trained.

Types of Cybersecurity Risk

Risk type	Meaning
Data breach risk	Sensitive data such as customer information or financial records is exposed or stolen.
Operational risk	An attack disrupts business operations, such as shutting down systems or halting services.
Financial risk	Losses from fraud, ransom payments, or penalties for non-compliance.
Reputational risk	Damage to brand image or customer trust after a cyber incident.
Compliance risk	Failing to meet industry standards or legal regulations on data protection.
Insider risk	Misuse by employees or accidental data leaks from within the organization.

Factors That Change the Level of Risk

- **How exposed the systems are.**
- **How valuable the data is.**
- **How strong the defenses are.**
- Example: customer data on an outdated system with no regular updates, while hackers actively exploit such weaknesses, makes the risk significantly high.

Factors Contributing to Cybersecurity Risk

- **Increasing sophistication of cyberattacks:** attackers keep developing new techniques and tools.
- **Evolving threat landscape:** new threats emerge regularly, so organizations must stay vigilant.
- **Lack of cybersecurity awareness:** insufficient training leads to human errors.
- **Complexity of IT infrastructure:** many devices, applications, and networks make security harder to manage.

Risk Calculation

Once we know an asset's vulnerabilities and threats, we can estimate how much risk the asset owner faces. Risk combines the likelihood that a threat exploits a vulnerability with the scale of the harmful consequences. The slides give several equivalent forms:

Formula	Meaning
Risk = Probability of threat x Cost to asset owner	Basic quantitative form
Risk = Threat x Vulnerability	Shorthand used in the slides
Risk = Likelihood x Consequence	Likelihood and consequence form
Risk = Likelihood of Occurrence x Potential Impact to Asset Owner	Expanded form
Risk = Threat x Vulnerability x Impact	Combines threat probability, exploitable vulnerability, and impact

- **Qualitative ratings:** many analyses use qualitative ratings (low, medium, high) because accurate probabilities and costs are hard to determine, especially for intangible assets such as trade secrets.
- **Example:** an unpatched software system that could lose an entire corporate data set is a massive risk. A photocopier with a default password poses a small risk.
- **Fluctuation:** risk changes with business decisions, such as a new investment, and with external factors, such as a new interest in an industry.

Risk Management

Risk management means assessing risks and deciding how to handle them. The slides list these options: **mitigation** (reducing the risk with controls), **acceptance** (living with the residual risk), and **transfer** (for example, with cyber insurance). Because you cannot eliminate every threat, risk management is an ongoing process.

8. Examples of Cyber Incidents

Incident	What happened	Lesson
1. Data breach from insiders (Tesla)	Two former employees leaked sensitive data, including Social Security numbers and contact details, of more than 75,000 people to a foreign outlet.	No advanced hacking was needed. Insider access was enough. (Insider threat)
2. Ransomware through a software vulnerability (MOVEit)	In mid-2023, the Clop ransomware gang exploited a known vulnerability in Progress Software's MOVEit Transfer. About 2,700+ organizations and nearly 100 million individuals were affected.	Known, unpatched vulnerabilities can have massive reach.

Incident	What happened	Lesson
3. Misconfiguration exposing data (MOVEit)	A separate misconfiguration in MOVEit Transfer left doors open to unauthorized access. No malware or credential theft was involved.	Preventable mismanagement can be as damaging as an attack.
4. Supply chain attack (Fortra GoAnywhere)	A zero-day in Fortra's GoAnywhere was exploited by the same ransomware group and exposed more than 130 organizations.	A weak link in the supply chain affects every customer.
5. Denial of service through a bad update (CrowdStrike)	A faulty update from CrowdStrike disrupted Microsoft systems worldwide. It was not a deliberate attack.	Outages can be as damaging as attacks, even when they are accidental.

9. Threats with Associated Risks

Threat type	Threat	Exploit / Vulnerability	Exposed risk
Human factor, internal	Intruder	No security guard or controlled entrance	Theft
Human factor, external	Hacker	Misconfigured firewall	Stolen credit card information
Human factor, internal	Current employee	Poor accountability; no audit policy	Loss of integrity; altered data
Natural	Fire	Insufficient fire control	Damage or loss of life
Natural	Hurricane	Insufficient preparation	Damage or loss of life
Malicious, external	Virus	Out-of-date antivirus software	Virus infection and loss of productivity
Technical, internal	Hard drive failure	No data backup	Data loss and unrecoverable downtime

10. Asset, Vulnerability, Threat and Risk Together

The model is a Venn diagram. **Threat**, **asset**, and **vulnerability** are three circles. **Risk** is the area where all three overlap. That means risk exists only when a threat can exploit a vulnerability in an asset that matters.

> **Universal truth:** you cannot eliminate or entirely protect against all threats, no matter how advanced your systems are.

11. Differences Between Vulnerability, Threat and Risk

Feature	Vulnerability	Threat	Risk
Definition	A weakness in a system, process, or human behavior that a threat can exploit	A potential danger that can exploit a vulnerability to breach security and cause harm	The potential for loss or damage that arises when a threat exploits a vulnerability
Nature	Static: exists whether or not it is exploited	Dynamic: can change or evolve	A consequence of a threat exploiting a vulnerability
Examples	Unpatched software, weak passwords, lack of training, misconfigured firewall	Malware, phishing, DoS attacks, insider threats, natural disasters	Data breach, financial loss, reputational damage, business disruption, legal liability

Feature	Vulnerability	Threat	Risk
Management	Patching, hardening systems, implementing controls	Threat intelligence, security awareness training, incident response planning	Risk assessment, mitigation, acceptance, or transfer (e.g., insurance)
Measurability	Can be counted (e.g., number of open ports)	Can be assessed (e.g., likelihood)	Measured in financial loss, downtime, etc.

Spectrum: a vulnerability exposes the organization to threats. A threat takes advantage of a vulnerability. The risk is the potential loss when the threat happens. The slides note that the terms threat and risk are sometimes used interchangeably, so be precise in exams.

12. Quick Revision Points

- Asset: anything of value to protect. Vulnerability: a weakness that can be exploited. Threat: a potential danger. Risk: possible loss.
- CISA defines a vulnerability as a set of conditions that may lead to failure of confidentiality, integrity, or availability.
- A successful exploit can crash programs (availability), execute code (integrity), or leak information (confidentiality).
- CVE identifies vulnerabilities (MITRE maintains the list). CVSS scores their severity from 0 to 10. Heartbleed is CVE-2014-0160 with CVSS 7.5.
- Know the CVSS bands: v2.0 Low 0.0 to 3.9, Medium 4.0 to 6.9, High 7.0 to 10.0; v3.x and v4.0 add Critical at 9.0 to 10.0.
- Threats are intentional, unintentional, or natural. Sources are nation states, terrorist organizations, criminal groups, hackers, and malicious insiders.
- Attack vector = the path. Attack surface = all exploitable points. Know the attack vector categories and their methods.
- Risk types: external or internal; data breach, operational, financial, reputational, compliance, insider.
- Risk formulas: Threat x Vulnerability (x Impact), or Likelihood x Consequence. Risk management options: mitigation, acceptance, transfer.
- Risk sits at the overlap of threat, asset, and vulnerability. You cannot eliminate all threats.

Source notes: The slides list the Tesla breach as involving "two former employees" and the MOVEit and GoAnywhere figures as reported at the time. The risk formulas differ slightly in form, but they express the same idea. Verify figures and dates against the original reports before the exam.

Vulnerability, Threat and Malware

Class 3 Notes: Vulnerability Management, CVE and CVSS, Insider Threats, Viruses, Worms, Trojans, Rootkits, Botnets, Malware Economics

Class outline: Part A covers vulnerabilities: causes, types, assessment and scanning, CVE, CVSS, vulnerability management, and patching. Part B covers threats and malware: insider threats, backdoors, logic bombs, viruses, worms, trojans, rootkits, bacteria and rabbits, bots, spyware and adware, countermeasures, and malware economics.

PART A: VULNERABILITIES

1. Causes of Vulnerabilities

- **Complexity:** complex systems increase the chance of a flaw, misconfiguration, or unintended access.
- **Familiarity:** common code, software, operating systems, and hardware make it easier for attackers to find known vulnerabilities.
- **Connectivity:** the more connected a device is, the higher the chance of a vulnerability.
- **Poor password management:** weak passwords can be broken by brute force, and reused passwords let one breach become many.
- **Operating system flaws:** systems that are insecure by default let any user gain access and inject viruses or malware.
- **Internet usage:** spyware and adware can be installed automatically on computers.
- **Software bugs:** programmers may leave exploitable bugs, accidentally or deliberately. Users who do not update leave software unpatched.
- **Unchecked user input:** if software assumes all input is safe, it may execute unintended SQL commands.
- **People:** the human at the end of the system is often the biggest vulnerability. Social engineering is the biggest threat to most organizations, and an in-house awareness program helps address it.

2. Common Cybersecurity Vulnerabilities

Vulnerability	Explanation
Zero day	A software flaw known to the adversary for which no fix exists, often because it has not been reported to the vendor.
Remote Code Execution (RCE)	Lets an attacker run malicious code on the vulnerable system, to steal data, deploy malware, or take other actions.
Poor data sanitization	Attacks such as SQL injection and buffer overflows submit invalid data. Failing to validate input leaves applications open.
Unpatched software	Flaws are corrected by patches or updates. Failing to patch out-of-date software leaves it open to exploitation.
Unauthorized access	Employees and contractors often get more access than they need. Abuse or account compromise then creates risk.
Misconfiguration	Security features are often set through configuration. Insecure configuration is common, especially in cloud environments.
Credential theft	Carried out through phishing, malware, and credential stuffing.

Vulnerability	Explanation
Vulnerable APIs	APIs get less attention than web apps, but can be even more damaging if not secured against unauthorized access.
Malicious insider	An employee or vendor with access to critical systems who steals, destroys, or impairs information. Most important for privileged users.
Missing or poor encryption	Lets an attacker intercept communication between systems and steal information.

3. Impact of Vulnerabilities

- **Data breach:** unauthorized access to confidential data.
- **System compromise:** complete takeover of the operating system, with loss of control over its functions.
- **Malware spread:** vulnerabilities are used to spread malware, ransomware, and other malicious software.

Why software vulnerabilities matter: an attacker who exploits one can crash programs (availability), execute arbitrary code (integrity), obtain sensitive information (confidentiality), and run with other users' privileges, which violates the desired access control policy.

4. Vulnerability Assessment Process

Step	What happens
1. Identify	Analyze network scans, pen test results, firewall logs, and vulnerability scan results to find anomalies that suggest an attack could use a vulnerability.
2. Verify	Decide whether the vulnerability could be exploited, and classify the severity to understand the risk.
3. Mitigate	If no patch exists, decide on countermeasures and how to measure their effectiveness. Mitigation reduces impact when a threat cannot be eliminated.
4. Remediate	Update the affected software or hardware where possible. Remediation completely removes the threat when that is possible.

Mitigate vs. remediate: mitigation reduces the impact; remediation removes the threat. Expect an exam question asking you to distinguish them.

5. Methods of Vulnerability Detection

- **Vulnerability scanning:** discovering, analyzing, and reporting security flaws using automated tools. It is an essential step in the vulnerability management lifecycle.
- **Penetration testing (pen test or ethical hacking):** a security expert attempts to find and exploit vulnerabilities.
- **Google hacking (Google dorking):** an information-gathering technique that uses advanced Google search queries to find vulnerabilities in web applications.

Credentialed vs. Non-Credentialed Scans

Scan type	How it works	Limitation or strength
Non-credentialed (non-authenticated)	No login. Gives an outsider's view of the environment.	Tends to miss most vulnerabilities inside the target.
Credentialed (authenticated)	Logs in with a set of credentials. Gives a trusted user's view.	Uncovers many vulnerabilities that non-credentialed scans overlook.

Top Vulnerability Scanning Tools (as listed in the slides)

Tool	Best for
Tenable	Best overall vulnerability scanner; enterprise option
Invicti	Comprehensive website and web application scans
StackHawk	Entry-level web app scanner for small DevOps teams
Nmap	Best open-source tool for free IT infrastructure and port scanning
ConnectSecure	Basic infrastructure scanning for service providers
Vulnerability Manager Plus	Entry-level endpoint and server scanner
Wiz	Specialist tool for clouds, containers, and infrastructure as code

6. Vulnerability Scanning vs. Penetration Testing

Both methods find weaknesses, but they differ in a key way. A **vulnerability scan** is an automated search for known vulnerabilities, signatures, or common errors such as weak passwords. A **penetration test** is an assessment by a human team (or partly automated) that actually **exploits** vulnerabilities to gain further access. It can also test attack vectors outside a scan's scope, such as social engineering and phishing.

Vulnerability Assessment (VA) vs. Penetration Testing

Feature	Vulnerability Assessment	Penetration Testing
Focus	Identifies potential vulnerabilities and prioritizes them by severity	Exploits vulnerabilities to understand real impact and compromise potential
Tools	Relies heavily on automated scanners	Mainly skilled experts; tools used for discovery or specific tasks
Performed by	Largely automated	Experts with deep knowledge of hacking techniques
Depth	Broad overview of weaknesses	Deeper understanding of exploitable vulnerabilities
Automation	High; allows frequent, quick scans	Limited; manual work needed to analyze and exploit
Frequency	Daily or weekly, depending on risk tolerance	Monthly, quarterly, or annually, depending on security needs
Compliance	Can support continuous compliance monitoring	Mandatory for compliance tests such as GDPR, HIPAA, ISO, CERT-IN, and SOX
Certification	Does not directly lead to a pen test certification	Can prepare for and demonstrate pen testing certification skills
Outcome	Report of vulnerabilities and severity levels	Report of exploited vulnerabilities, the attacker's path, and remediation strategies
Cost	Lower, due to automation	Higher, due to skilled personnel

Penetration testing tools listed: vPenTest, Metasploit, BreachLock (Penetration Testing as a Service), Edgescan, NetSPI Penetration Testing Services, and Astra. **VAPT** (vulnerability assessment and penetration testing) is usually carried out regularly, at fixed intervals, in important organizations.

7. CVE, CNA and NVD

CVE: Common Vulnerabilities and Exposures

- CVE's primary purpose is to **uniquely identify vulnerabilities** and link specific versions of code bases to them.
- An **exposure** is a mistake that gives an attacker access to a system or network. Exposures can lead to data breaches and leaks.
- The goal is to make it easier to share information about known vulnerabilities, so security strategies can keep up with the latest flaws.
- Founded in **1999**. Maintained by the **MITRE Corporation**, a not-for-profit that operates federally funded R&D centers.
- Sponsored by the U.S. Department of Homeland Security (DHS), the Cybersecurity and Infrastructure Security Agency (CISA), and US-CERT.

CVE Entry Format

Each CVE entry has a **standard identifier number** with a status indicator (for example, CVE-1999-0067 or CVE-2014-12345), a brief description, and references to related vulnerability reports and advisories.

How a Vulnerability or Exposure Is Added to CVE

- A researcher finds a flaw or design oversight in software or firmware. The vendor does not have to agree that it is a vulnerability.
- The researcher must supply evidence of how it could be used in an exploit.
- Reports from established vendors or other trusted parties are usually added quickly.

CNA: CVE Numbering Authorities

- CNAs are organizations that identify and distribute CVE IDs to researchers and vendors for public announcements.
- They include software vendors, open source projects, coordination centers, bug bounty providers, and research groups. Bug bounty programs reward ethical hackers for reporting bugs to developers.
- CNAs form a **federated system**. They assign IDs without directly involving MITRE, which is the primary CNA.
- The slides report **104 CNAs in 18 countries**, including Microsoft, Adobe, Apple, Cisco, Google, IBM, Intel, Oracle, Red Hat, and Siemens.

NVD: National Vulnerability Database

The NVD is maintained by **NIST** and is fully synchronized with the MITRE CVE list. It provides CVSS enrichment for all published CVE records and supports CVSS v2.0, v3.x, and v4.0.

8. Common Vulnerability Scoring System (CVSS)

CVSS is a method for giving a **qualitative measure of severity**. It assigns a number to a vulnerability to show its severity, on a scale from **0.0 to 10.0**. The higher the number, the more severe the vulnerability. NVD, CERT, UpGuard, and others use CVSS scores to assess impact.

> **Key point:** CVSS is **not a measure of risk**. It measures severity. It does not account for the specific exploit context or the likelihood of exploitation, and it is not a threat model.

CVSS v2.0 and v3.x have three metric groups: **Base**, **Temporal**, and **Environmental**.

Base Metrics (intrinsic characteristics)

Base metrics describe the vulnerability itself, whether or not it has been exploited or mitigated. They include exploitability, scope, and impact.

- **Exploitability** has four sub-components: **Attack Vector** (higher for remote attacks than for attacks needing physical access), **Attack Complexity** (lower for easier attacks), **Privileges Required** (higher when fewer privileges are needed), and **User Interaction** (higher for autonomous attacks that need no user).

- **Scope:** whether the vulnerability can affect components beyond the initial target. A flaw that compromises a whole system through one application scores higher.
- **Impact:** the consequences of a successful exploit on **Confidentiality** (extent of data exposure), **Integrity** (ability to modify data), and **Availability** (disruption of access and functionality).

Temporal Metrics (change over time)

- **Exploit Code Maturity:** the score rises as exploit code matures and spreads.
- **Remediation Level:** the score falls as temporary fixes or official patches are released.
- **Report Confidence:** how well the vulnerability is validated as real and exploitable. Higher confidence means a higher score.

Environmental Metrics (organization-specific)

- **Security Requirements:** the criticality of the affected asset. A database with all customer data scores higher than a non-privileged user's workstation.
- **Modified Base Metrics:** adjusts base metrics for existing mitigations. For example, air gapping a server lowers the Attack Vector score, because remote exploitation is no longer possible.

Limitations: base metrics alone do not account for temporal or environmental factors, which can change the perceived risk. Organizations should consider all three groups.

CVSS Qualitative Severity Ratings

Severity	CVSS v2.0	CVSS v3.x	CVSS v4.0
None	-	0.0	0.0
Low	0.0 to 3.9	0.1 to 3.9	0.1 to 3.9
Medium	4.0 to 6.9	4.0 to 6.9	4.0 to 6.9
High	7.0 to 10.0	7.0 to 8.9	7.0 to 8.9
Critical	-	9.0 to 10.0	9.0 to 10.0

CVSS vs. CVE

- **CVE** gives each vulnerability a unique identifier, so it can be tracked.
- **CVSS** gives that vulnerability a severity score. Example: Heartbleed (CVE-2014-0160) has a CVSS score of 7.5, which indicates high severity.

9. Vulnerability Management

Vulnerability management is a **continuous, proactive, and often automated process** that keeps systems, networks, and enterprise applications safe from attacks and breaches. It requires more than scanning and patching. It also needs a 360-degree view of the organization's systems, processes, and people.

Component	What it does
Asset discovery and inventory	Tracks and records all devices, software, and servers across the digital environment. This is complex when there are thousands of assets across many locations.
Vulnerability scanners	Run tests against systems and networks to find weaknesses, such as attempting to exploit known vulnerabilities, guessing default passwords, or trying to reach restricted areas.
Patch management	Software that keeps systems up to date with the latest security patches.
Configuration management (SCM)	Ensures devices are configured securely, tracks and approves changes to security settings, and checks compliance with policy.

Component	What it does
SIEM	Consolidates security information and events in real time, giving visibility across the whole digital estate.
Penetration testing	Software that helps professionals find and exploit vulnerabilities, usually with a graphical interface.
Threat intelligence	Collects data from exploit databases and security advisories to spot trends that may indicate future breaches.
Remediation	Prioritizes vulnerabilities, plans next steps, and creates tickets so IT teams can act. Tracks that each fix is completed.

10. Software Patches and Patch Management

A **patch** is a software update for an existing application or operating system that fixes bugs or vulnerabilities. It is also called a **fix** or **bugfix**. Many vendors have fixed cycles. For example, Microsoft usually releases patches on the **second Tuesday of each month**, known as **Patch Tuesday**. Critical security patches can come outside this cycle.

Types of Software Patches

Type	Purpose
Security patches	Fix security vulnerabilities in software, drivers, and related components so they cannot be exploited.
Bug fix patches	Fix bugs ranging from minor to critical, keeping software on its latest bug-free version.
Feature update patches	Add new features and functions, and improve performance and efficiency.

Why Patch Management Matters

Patch management is the process of **identifying, testing, deploying, and installing** patches on computers.

- **Preventing security breaches:** patches fix vulnerabilities in software and applications, keeping attacks away.
- **Ensuring compliance:** with attacks on the rise, regulators require enterprises to meet compliance mandates.
- **Feature updates:** improve usability and the end-user experience.
- **Downtime prevention:** ransomware and other threats cause downtime that affects productivity and revenue.

> **Conclusion of Part A:** as networks grow more complex, managing vulnerabilities actively is essential. That requires visibility of internal and third-party networks, and IT staff who understand vulnerabilities, their impact, and how to fix them.

PART B: THREATS AND MALWARE

11. Insider Threats

An **insider threat** is a security risk from a current or former employee or business associate who misuses their access to an organization's network. It can involve leaking data, sabotaging equipment, or stealing property. Insider threats are hard to detect and fight. Employees, partners, vendors, interns, suppliers, and contractors can all become insider threats.

Six Types of Insider Threat

Type	Description
1. Departing employees	Leaving voluntarily or involuntarily. They may take materials to help land a new job, or steal and expose sensitive data out of revenge.
2. Malicious insiders	Current employees who act on grievances by altering or deleting data, disclosing secrets, or sabotaging.
3. Negligent workers	Careless employees who skip security hygiene (weak passwords, no MFA, sharing work devices). Often more dangerous than malicious insiders.
4. Security evaders	Workers who find security policies inconvenient and build workarounds that increase breach chances.
5. Inside agents	Insiders who work for an external group, knowingly or unknowingly, through blackmail, bribery, or social engineering.
6. Third-party partners	Suppliers, contractors, and vendors with inside access. As dangerous as employees with the same permissions.

Defenses Against Insider Attacks

- **Educate employees** on data handling policies and the limits of their access.
- **Implement access controls** to limit who can reach sensitive data.
- **Apply the principle of least privilege:** give users only the data, resources, and applications their job needs.
- **Conduct risk assessments** regularly to keep systems secure and current.
- **Use threat modelling** to identify and prevent attacks, including insider attacks.
- **Monitor user behaviour** with tools that detect anomalies.
- **Establish incident response procedures** for responding to and reporting incidents.
- **Identify sensitive assets** and assess how accessible they are to different insiders.

12. Backdoor and Trapdoor

A **backdoor** (or trapdoor) is a method that lets unauthorized users bypass security mechanisms and gain access to a system. Some backdoors are created for legitimate purposes, but attackers also use them. Backdoors can come from design flaws, coding errors, or malicious code. They can stay undetected for weeks. Once an attacker is in, they can modify files, steal personal information, install software, and take control of the whole system.

Dangers of Backdoor Threats

- Stealing personal information
- Installing unwanted software
- Taking control of the entire computer
- Changing the infrastructure, and making the system behave as the attacker wants
- Launching DDoS attacks
- Infecting website visitors

13. Logic Bombs

A **logic bomb** is malicious code hidden in a system or application. It stays dormant until its trigger conditions are met, and then it causes harm. It may be used for revenge, profit, or simply to cause havoc. For example, a disgruntled employee might insert a logic bomb that deletes files when they are terminated.

Common Triggers and Destructive Effects

Triggers	Destructive actions
A specific date or time; event-based triggers; user actions; system conditions	Deleting files; corrupting data; crashing systems; disrupting critical systems; data loss; financial losses; loss of productivity

> **Exam point:** logic bombs do **not** self-replicate and do not spread to other systems. That is what separates them from viruses and worms.

14. Malware

Malware (malicious software) is software designed to disrupt a computer or network, steal data, or damage a system. It is developed by cybercriminals, often called hackers. Its goal is to cause harm, for financial gain or sabotage. Common examples are viruses, worms, trojans, rootkits, spyware, adware, and ransomware.

Malware type	One-line description
Virus	Spreads between programs and computers by attaching to a host file, and damages data and software.
Worm	Replicates itself and spreads across networks without human interaction.
Trojan horse	Looks like a legitimate program but hides malicious functions. Does not inject itself into other programs.
Rootkit	Gives the attacker complete control while staying hidden for a long time.
Spyware	Gathers private information and passes it to a third party without the user's knowledge.
Adware	Automatically displays unwanted advertisements to generate revenue.
Ransomware	Encrypts files or systems and demands payment for their release.

15. Computer Viruses

A **computer virus** is malware that spreads between computers and damages data and software. Viruses typically attach to an executable host file. Their code runs when that file is opened, and then it spreads through networks, drives, file-sharing programs, or infected email attachments. A key feature is that the victim must run the code or payload, which means the host application must be running.

- **Early days:** viruses spread between devices on floppy disks.
- **Today:** they still spread via hard disks and USB devices, but mostly through the internet, including email. Some can hijack email software to spread themselves.

Four Phases of a Virus

Phase	What happens
1. Dormant	The virus enters the computer or software but does nothing.
2. Propagation	The virus multiplies and inserts copies of itself into other programs or areas of the disk.
3. Triggering	The virus changes from dormant to active, through a specific user action or a predefined date.
4. Execution (action)	The virus releases its payload, the malicious code that harms the device.

Types of Computer Viruses

Type	Key behaviour
Resident virus	Embeds itself in RAM, so it stays active and infects files even after the original program closes. Infects programs as they are opened.

Type	Key behaviour
Non-resident virus	Infects executable files when programs are not running.
Multipartite virus	Stays in memory, infects the hard disk, and spreads to other drives by altering application content. Causes lag and low memory.
Direct action virus	Infects programs, files, and folders on the autoexec.bat path, then deletes itself. Can destroy data on the hard disk and attached USB devices.
Browser hijacker	Changes browser settings (homepage, new tab page, default search engine) without permission. Technically not a virus, because it cannot infect files.
Overwrite virus	Deletes data and replaces it with its own content. Infected files cannot be restored. The only removal is deleting all infected files.
Web scripting virus	Exploits browser security to inject web pages with malicious client-side script. Used to send spam, commit fraud, and damage server files.
File infector	Overwrites files when they are opened and spreads quickly across systems. Mainly affects .exe and .com files.
Network virus	Cripples entire networks. Hard to find because it can hide on any computer on an infected network. Spreads over the internet.
Boot sector virus	Targets the master boot record (MBR), injects code into the partition table, and loads into memory at restart. Shown by boot-up problems.

16. Encrypted, Polymorphic and Metamorphic Viruses

An **encrypted virus** uses encryption to hide its code and avoid detection. The code looks like gibberish, so **signature-based** antivirus cannot recognize it. The simplest form has an encrypted virus body and a small, unencrypted **decryptor** that holds the key and routine to unscramble the body.

Feature	Polymorphic virus	Metamorphic virus
Core technique	Encrypts its body and uses a variable decryptor	Rewrites its entire code, including the engine
Signature	Body changes, but the decryptor often has a detectable signature (hidden with junk code)	No part stays the same. No constant decryptor or body
How it changes	Variable encryption key changes the code, so each copy looks different	Mutation engine uses garbage code, register exchange, instruction replacement, permutation, and code transposition
Complexity	Less complex	Extremely complex to create
Analogy	A letter locked in a safe: the lock changes, but the letter is the same	The letter is rewritten in a different language and handwriting, but says the same thing

Polymorphic malware is more common than metamorphic malware. It is also easier to identify, because only part of its code changes.

Detecting Polymorphic Viruses

- **Behaviour-based detection:** analyzes the virus's behaviour as well as its code, so it can catch viruses with similar behaviour.
- **Heuristic scanning:** looks for components that different threats share, rather than an exact match. This detects new variants.
- Newer technologies that use machine learning and behaviour detection can spot anomalous activity that signature scanners miss.

17. Virus Signatures and Their Limitations

A **virus signature** is a unique pattern of code or data that identifies a specific virus, like a fingerprint. Antivirus software scans files and compares them against a database of known signatures. On a match, it removes or isolates the threat.

Limitation	Explanation
Only detects known threats	Signature scanners can only find malware that already has a signature. The gap between a new malware's release and the database update is a **zero-day** window.
Vulnerable to polymorphic and metamorphic viruses	These change their code with each infection, creating a new signature every time, so signature methods struggle to keep up.

18. Preventing Computer Viruses

- **Use a trusted antivirus product** with regular scans to identify and block malware.
- **Avoid clicking pop-up advertisements,** which can lead to downloading viruses without knowing it.
- **Scan email attachments.** Avoid suspicious attachments, which are a common route for malware. Antivirus can scan them.
- **Scan downloaded files from file-sharing programs.** Avoid software, games, or apps from unofficial sites, and always scan downloads.

19. Trojan Horse

A **Trojan horse** is malware disguised as a legitimate program. It appears to perform a desired function but has hidden code that can steal information, create backdoors, or run scripts. Attackers use social engineering to hide the malicious code inside legitimate software. Trojans are often confused with viruses, but unlike viruses they are usually **stand-alone programs** and do not inject themselves into other programs. Malicious code can be hidden in benign applications, in JavaScript pages, or in email links.

Actions a Trojan Can Take

- Stealing sensitive data such as passwords and financial information
- Corrupting or deleting files
- Taking control of the device for malicious purposes
- Installing other malware
- Disrupting the device's operation

Types of Trojans

Type	Description
Backdoor Trojan	Gives the attacker remote administrative control of the system
DDoS Trojan	Launches DoS attacks by sending many requests to a target address
Trojan Downloader	Downloads and installs files, often malicious programs
Info-stealer Trojan	Steals important data from susceptible systems
Banker Trojan	Targets financial account information and tries to access bank, investment, and credit card accounts
Zeus (Zbot)	Designed to steal credit card details and passwords
CryptoLocker	Encrypts files on the device and any connected media

20. Computer Worms

A **computer worm** is malware that replicates itself and spreads to other computers **without human interaction**. It exploits security vulnerabilities to gain access, then uses that computer as a host to infect others. As it spreads, it consumes bandwidth, which overloads infected systems and makes them unreliable or unavailable. Worms can also change or delete files, or introduce other malware.

What Worms Can Do

- **Steal information** by exploiting vulnerabilities in security software
- **Install backdoors** that hackers can use
- **Corrupt files** and **crash systems** through self-replication
- **Download malicious applications**
- **Overload systems** by consuming memory and bandwidth

Worms are hard to eradicate because they spread quickly and automatically. Even one without a malicious payload can be a nuisance for IT managers.

Virus vs. Worm

Aspect	Virus	Worm
How it spreads	Depends on a host file or boot sector, and on transfer of files between machines	Runs independently and spreads over network connections
Activation	Needs the user to interact with an infected file or program	Acts on its own, with no user action
Resource effect	Effect depends on the payload	Can consume a lot of memory and network bandwidth

21. Rootkits

A **rootkit** is malware that gives cybercriminals unauthorized access to a computer or network. It is designed to be hard to detect and can stay hidden for a long time. It is a toolbox for infecting computers, giving the attacker remote control, and staying hidden. A rootkit gives **complete control** of the system, while a Trojan gives only **limited** access.

Blended Malware and Droppers

Rootkits and worms are different types, but they can be combined. A worm might spread across a network with a rootkit as its payload, or carry a **dropper** that installs a Trojan or virus, which then runs a rootkit. A **dropper** is malware that installs other malware, often in the first stage of an attack. Its features are:

- **Disguising itself** as a harmless file, such as an installer, or a genuine app like a calculator or QR scanner
- **Exploiting vulnerabilities** in document formats such as PDF or Microsoft Office files
- **Installing payloads**, the other malicious tools, without the victim noticing
- **Neutralizing system defences** before installing the payload

Rootkit detection is difficult because the infected programs still run normally. Antivirus programs can detect some rootkits because both operate at the application layer. Many rootkits need specialized anti-rootkit software or an OS reinstall.

Rootkit vs. Worm

Feature	Rootkit	Worm
Primary purpose	Hide itself and other malware; maintain persistent, undetected access	Self-replicate and spread, consuming resources and causing disruption
Main behaviour	Stealth: modifies the OS core to hide files, processes, and network connections	Propagation: copies itself across networks, email, or vulnerabilities

Feature	Rootkit	Worm
Method of spread	Does not self-replicate. Usually installed by another threat	Self-replicating. Spreads automatically, often by exploiting vulnerabilities
User interaction	Often installed without the user being directly involved	Can spread with no user action, or use social engineering
Primary target	Integrity and security of one specific machine	Any vulnerable system it can reach on a network
Key danger	Stealthy control, with long-term root (administrator) access	Network congestion and resource drain, causing slowdowns or crashes
Visibility	Designed to be invisible to users and standard antivirus	Its activity (traffic, slow performance) is often noticeable
Removal	Very difficult. Often needs anti-rootkit software or an OS reinstall	Standard antivirus can remove it, but rapid spread makes containment a priority

22. Bacteria and Rabbits

Viruses that perform no explicit malicious behaviour are called **bacteria** or **rabbits**. Unlike destructive malware that deletes files, steals data, or encrypts systems, they simply replicate themselves continuously. They do not directly damage data, but they can still severely harm a system. They consume CPU, memory, and disk space until the system slows, crashes, or becomes unusable. Examples are the **Rabbit virus (1974)** and **fork bombs** in Unix and Linux. Their impact is resource exhaustion, which is a form of denial of service.

Feature	Bacteria / Rabbit	Traditional virus	Worm
Replication	Local, exponential self-replication	Attaches to host files; replicates when executed	Network-based; self-propagating
Malicious payload	None, just replication	Often destructive (deletes or steals data)	May carry a destructive payload
Resource consumption	Very high; can crash the system	Moderate; depends on the payload	High; spreads rapidly over networks
Spreading method	Within one machine	Via infected files or media	Across networks automatically
Impact type	Denial of service (DoS)	Data loss, corruption, theft	Network slowdown, mass infection, ransomware

23. Key Historical Malware Examples

Year	Malware	What it did
1974	Rabbit virus	Endless replication that crashed systems (DoS)
1988	Morris Worm	The first major Internet worm. It overloaded thousands of systems
2000	ILOVEYOU virus	Email-based. Overwrote files and spread globally
2017	WannaCry worm	Ransomware worm that exploited Windows SMB (Server Message Block) and caused worldwide disruption

24. Bots and Botnets

A **bot** is a software program that operates on the Internet and performs repetitive tasks. Some bots are beneficial, but malicious ones can severely damage a website or application.

Types of Bots

Type	Description and examples
Chatbots	Simulate human conversation. Examples: Siri, Alexa, Google Assistant
Web crawlers	Scan webpages across the Internet. Examples: Googlebot, bingbot, Amazonbot
Social bots	Operate on social media platforms. Example: Twitterbots
Malicious bots	Scrape content, spread spam, or carry out credential stuffing

Malicious Bot Activity

Any automated action by a bot that violates the site owner's intentions or Terms of Service. Examples:

Common malicious bot activities		
Credential stuffing	Web or content scraping	DoS or DDoS attacks
Brute force password cracking	Inventory hoarding	Spam content
Email address harvesting	Click fraud	

Botnets

A **botnet** is a network of internet-connected devices (computers, smartphones, IoT devices) infected with malware and controlled remotely by a cybercriminal. The criminal is called the **bot master** or **bot herder**. Botnets are the engine behind many DDoS attacks.

25. Privacy-Invasive Software: Spyware and Adware

Privacy-invasive software is built mainly to capture a target's private information. It ignores the user's privacy and tracks their activity.

Software	Description
Spyware	Gathers an individual's or organization's private information without their knowledge, and passes it to a third party. Often has malicious intent. Examples: trojans, system monitors, and tracking cookies. Can collect browsing habits and bank account information.
Adware	Also called advertising-supported software. Built for commercial intent. Automatically shows unwanted ads to generate revenue for its developer, through display ads or pay-per-click.

26. Methods of Malware Attacks

Malware can infiltrate and spread through networks in several ways:

- **Unsecure devices** that access the network, such as personal mobile devices, PCs, and IoT devices.
- **Unsecure supply chain networks** or third-party partner networks, which can infect other networks.
- **Older devices** with software that is not routinely updated.
- **Email attachments** with malicious code, which can be forwarded to other users.
- **Phishing and spear phishing** emails that trick recipients into sharing passwords that give access to the corporate network.
- **Smishing** texts, the mobile version of phishing, which trick distracted users into clicking malicious links.
- **File servers** (for example, CIFS or NFS shares) that spread malware as users download infected files.
- **File-sharing software** that copies malware onto removable media such as thumb drives, and then onto systems and networks.
- **Peer-to-peer (P2P) file sharing**, where infected files disguised as video, music, or images are shared.
- **Remotely exploitable network vulnerabilities**, which let a hacker reach systems from anywhere in the world.

27. Countermeasures Against Malware

#	Countermeasure	Detail
1	Install antivirus software	On all network-connected devices, and update it regularly
2	Update software	Keep computers and software at their latest versions
3	Use security tools	Firewall, intrusion prevention system (IPS), and endpoint monitoring
4	Use email security	Filters that scan and remove malicious attachments and suspicious links
5	Use web filters	Block access to websites that host malicious content
6	Use multi-factor authentication (MFA)	Adds an extra layer of security to accounts
7	Back up your data	Multiple copies, using different backup solutions and storage locations
8	Use a non-administrator account	An administrator account has full permissions, including changes that affect other users
9	Develop security policies	And implement security awareness training
10	Perform vulnerability assessments	Routine assessments to find and fix weaknesses

28. Economics of Malware

The economics of malware is driven by cybercriminals' desire to make money. The slides project that the cost of cybercrime will rise significantly in the coming years.

Area	Figure or fact (as stated in the slides)
Annual damage	Malware causes over $13 billion of economic damage worldwide each year
Cybercrime forecast	Cybersecurity Ventures estimates cybercrime costs will reach $10.5 trillion annually by 2025
Ransomware	Check Point Research estimates the GandCrab ransomware attack generated $300,000 to $600,000 in ransom payments
Distribution	Malware can be installed alongside other downloads, including from third-party websites and P2P networks
New malware	About 560,000 new pieces of malware are detected every day
Total malware	Over 1 billion malware programs are estimated to exist
Trojans	Trojans account for 58% of all computer malware
Ransomware frequency	Every minute, four companies fall victim to ransomware attacks

29. Conclusion of Part B

Malware is a persistent and evolving threat. Its forms range from simple viruses made for mischief to sophisticated ransomware and state-sponsored attacks. Fighting it takes more than antivirus software. It needs constant vigilance, proactive security practices, and shared responsibility among individuals, companies, and governments.

30. Quick Revision Points

- Causes of vulnerabilities: complexity, familiarity, connectivity, poor passwords, OS flaws, internet usage, bugs, unchecked input, and people.
- Vulnerability scan = automated search for known flaws. Pen test = human-led exploitation. Credentialed scans find more than non-credentialed scans.

- Mitigate reduces the impact. Remediate removes the threat.
- CVE identifies vulnerabilities (MITRE, founded 1999). CNAs issue IDs. NVD (NIST) enriches CVEs with CVSS.
- CVSS measures severity from 0.0 to 10.0. It is **not** a risk score. Base metrics are exploitability, scope, and impact. Temporal and environmental metrics adjust the score over time and for the organization.
- Vulnerability management is continuous. Patch types: security, bug fix, feature update. Patch Tuesday is the second Tuesday of each month.
- Insider threats: six types. Defences include least privilege, access controls, and monitoring.
- Backdoor = bypass of security. Logic bomb = dormant until a trigger, and does not self-replicate.
- Virus = needs a host and user execution. Worm = self-spreads over networks. Trojan = disguised, stand-alone. Rootkit = hidden, root-level control. Bacteria or rabbit = self-replicates until resources run out.
- Polymorphic changes its encryption and decryptor. Metamorphic rewrites its whole code. Signature detection cannot catch either reliably. Behaviour and heuristic detection can.
- Bot = automated program. Botnet = infected devices under a bot master. Spyware gathers private data. Adware shows unwanted ads.
- Know the four historical examples: Rabbit (1974), Morris Worm (1988), ILOVEYOU (2000), WannaCry (2017).

Source notes: The slides name the CVE sponsors as DHS, CISA, and US-CERT. The Class 2 notes said the National Cyber Security Division (NCSD). The slides also use both "Common Vulnerabilities and Exposures" and "Common Vulnerability Enumeration." Several figures (for example, the $13 billion, 560,000 per day, and 58% trojan share) are as reported in the slides and should be verified against the original sources before the exam.

Overview of Cloud Computing

Class 4 Notes: Definition, Characteristics, Service and Deployment Models, Enabling Technologies, Drivers, Edge and Fog Computing

Core idea of this class: cloud computing delivers computing as an on-demand utility over the Internet. Users rent resources, such as servers, storage, and software, and pay for what they use, without owning or managing the underlying hardware. Expect exam questions on the NIST definition, the five characteristics, the three service models, and the four deployment models.

1. Introduction and Background

- **1965:** Corbato et al. proposed a business model for **on-demand computing** on a **pay-as-you-go** basis. Customers choose the resources they need (CPUs, memory, bandwidth, platforms) from the vendor.
- **2005 to 2006:** cloud computing emerged as a new distributed computing model, with the aim of treating computing as a **utility**. Users would obtain it the way they obtain water, electricity, gas, and telephone service.
- The cloud moves services **outside the organization's firewall**. Applications, storage, and other services are accessed over the Web.

2. Definition of Cloud Computing

NIST Definition (summarized)

The National Institute of Standards and Technology (NIST) describes cloud computing as a model for enabling convenient, **on-demand network access** to a **shared pool of configurable computing resources** (networks, servers, storage, applications, and services). These resources can be **rapidly provisioned and released** with minimal management effort or interaction with the service provider.

Other Definitions from the Slides

- The delivery of computing services (servers, storage, databases, networking, software, analytics, and intelligence) over the Internet, to offer faster innovation, flexible resources, and economies of scale.
- The provision of **dynamically scalable and often virtualized** resources as a service over the Internet, on a utility basis. Users need no knowledge of, expertise in, or control over the technology infrastructure in the cloud.

Why it reduces cost: one physical machine can serve many needs and organizations. This makes the use of physical hardware more efficient, and avoids the need to install physical servers, run one's own software, or manage one's own databases.

3. Essential Characteristics of Cloud Computing

Characteristic	Meaning
On-demand self-service	Consumers request, manage, and access services directly through web services and management interfaces, without human interaction. Resources are available instantly.
Broad network access	Services can be reached from any standard device (mobile phone, PC, desktop, laptop) from any location, at any time, given adequate IP networking.
Resource pooling	The provider pools large physical or virtual resources shared by multiple users. Resources are allocated dynamically in a multi-tenant environment.
Rapid elasticity	Capacity scales with consumer requirements. Capacity rises in busy periods and falls in off-peak periods. Resources can be bought as needed, on a pay-per-use basis.

Characteristic	Meaning
Measured service	Usage is monitored and metered, for example by storage used, CPU hours, and bandwidth. The metering system controls and scales resources and billing automatically.

4. Service Delivery Models

Cloud services are classified by **what the consumer gets**. There are three service models, and each gives the consumer a different level of control over the stack.

Model	What the consumer gets	Consumer control	Examples (from slides)
SaaS: Software as a Service	Applications running on the cloud, used mainly through a web browser	Does not control the underlying system, servers, network, operating system, or storage	Dropbox, Google Apps, GoToMeeting
PaaS: Platform as a Service	A development environment deployed onto the cloud. Developers build applications with the languages and tools the provider supports	Controls the applications it builds, within the provider's tools and languages	Google App Engine, Microsoft Azure
IaaS: Infrastructure as a Service	Processing, storage, networks, and other fundamental computing resources, on which the consumer can deploy and run any software	Controls operating systems, storage, and deployed applications, with limited control of some networking components	Amazon Web Services (AWS), Cisco Metapod, Microsoft Azure, Google Compute Engine (GCE)

Easy way to remember control: as you go from SaaS to PaaS to IaaS, the consumer controls more of the stack. In SaaS, the provider manages almost everything. In IaaS, the consumer manages the operating system and above.

5. Deployment Models

A deployment model shows **how cloud resources are organized and shared**. There are four models: private, public, community, and hybrid. Each affects scalability, reliability, security, and cost.

Model	Description	Key point
Private cloud	Used exclusively by one organization, company, or one of its customers. Operated internally by that organization, or through a third-party auditor.	Control and privacy, but limited sharing
Public cloud	Run and managed by the Cloud Service Provider (CSP). The physical infrastructure may be at an off-site location. Resources are shared among many users, who pay for what they use.	Shared, pay-per-use, typically the most scalable
Community cloud	Serves a limited number of individuals or organizations. Governed, managed, and secured jointly by the participants, or by a third-party managed service provider.	Shared by organizations with common goals, such as joint projects or research
Hybrid cloud	A mix of on-premises or private cloud and third-party public cloud services, with orchestration between the two.	Workloads can move between private and public clouds as needs and costs change

6. Cloud Roles and Boundaries

The cloud provides predefined roles for organizations and people. The slides list six roles:

Role	Meaning (standard NIST cloud reference model)
Cloud provider	Makes cloud services available to consumers. Builds, manages, and delivers the services.

Role	Meaning (standard NIST cloud reference model)
Cloud consumer	Uses the services and has an agreement with a provider.
Cloud service owner	Owns and manages the service's functions and its relationship with consumers.
Cloud resource administrator	Manages and maintains the cloud resources that deliver the service.
Cloud broker	Adds value by managing, integrating, or securing the use of cloud services for consumers.
Cloud carrier	Provides the network connectivity that carries cloud services from provider to consumer.

Note: the slides name these six roles without giving definitions. The meanings above are the standard NIST cloud reference model definitions, so check them against your lecturer's wording.

7. Leading Cloud Computing Companies

Company	Platform	Model (as labeled in the slides)
Amazon Web Services (AWS)	Rents virtual computers on Amazon's infrastructure	IaaS
Microsoft Azure	Lets .NET Framework applications run over the Internet, as an alternative platform for developers	PaaS
Google Cloud Platform (GCP)	Built on Google's worldwide data center network. Google offers free software based on this infrastructure	SaaS (see source note)

Source note: the slides label Google's offering as SaaS. Google Cloud Platform itself is usually discussed as an IaaS and PaaS provider, and its free products are SaaS. Use the slides' wording in your answer, but know the nuance.

8. Technologies in Cloud Computing

Cloud computing is not one technology. It combines many existing technologies that matured at different rates and were not designed as one system. Together they form a technical ecosystem for the cloud.

Technology	Role in the cloud
Cloud access devices	The range of devices that reach the cloud has grown: PCs, network computers, mobile phones, and custom devices, all online.
Web technology	Users on any device can reach applications from any browser. The two fundamental components are the web client and web server. Proxies, routers, cache servers, and gateways are secondary components.
Broadband network and Internet	A critical component. It connects all the parts of the cloud, and is widely available in global metropolitan areas.
Data centers and server farms	Combine multiple technologies. They contain both physical and virtualized IT resources.
Storage devices	Fixed direct access storage (DASD) has been replaced by storage area networks (SANs). SAN software allocates storage on demand across many devices, which cuts cost and adds flexibility.
Virtualization	Abstracts compute resources (CPU, storage, network, memory, application stack, database) from the applications and users that consume them. It enables multi-tenant business models with a scalable shared platform.

Technology	Role in the cloud
Service technology or API	Lets consumers use cloud services, in forms ranging from simple URL manipulation to SOA-style programming models. APIs hide the complexity of extending IT management processes to the cloud.
Multi-tenant technology	The same application logic serves many users at the same time. Common features are usage isolation, data recovery, data tier isolation, data security, application upgrades, scalability, and metered usage.

9. Key Drivers of Cloud Adoption

Driver	Explanation
Small initial investment and low ongoing cost	Public cloud avoids capital expenditure, since no hardware, software, or network devices must be bought. Billing is only for actual use, so it is an operating expense rather than a large investment.
Economies of scale	Projects need to estimate storage, processing, and memory for development, testing, and production. With cloud flexibility, companies acquire computing and development services as needed, on demand.
Open standards	Cloud capabilities built on open standards support modular architectures that can grow quickly and change when required. Flexibility to alter source code is essential for continued growth.
Sustainability	Providers invest heavily in resilient architecture. Customers benefit from fewer points of failure, better resilience through clustering, and access to state-of-the-art resilience solutions.

10. Uses of Cloud Computing

- **Create new apps and services:** build, deploy, and scale web, mobile, and API applications quickly. Build, test, and remove environments quickly, to reach market faster.
- **Store, back up, and recover data:** offsite cloud storage accessible from any location and device. Improves disaster recovery and business continuity.
- **Stream audio and video:** high-definition media with global distribution, on any device.
- **Deliver software on demand (SaaS):** offer the latest versions and updates to customers, whenever and wherever they need them.
- **Work with big data analytics and AI:** use cloud processing power to analyze big data and run machine learning and AI applications.
- **Support a mobile workforce:** virtual desktops, and cloud email and messaging, for remote workers on any device.

11. Edge Computing

Edge computing is described in the slides as a subsection of cloud computing. Cloud computing hosts applications in a core data center. Edge computing hosts applications **closer to end users**, either in smaller edge data centers or on customer premises. It optimizes internet devices and web applications by bringing computation close to the source of the data.

- It reduces the need for long-distance communication between client and server, which **reduces latency and bandwidth use**.
- It runs fewer processes in the cloud and moves them to local places, such as a user's computer, an IoT device, or an edge server.

Worked Example: Smart Building Cameras

Imagine a building with dozens of high-definition IoT cameras that simply output raw video and stream it to a cloud server. The cloud server runs motion detection on all the footage, so only clips with activity are saved. This strains the building's internet connection, because large volumes of video cross it, and it overloads the server, which must process every camera's footage at once.

With edge computing, each camera has its own internal computer that runs the motion detection. It sends footage to the cloud only when needed. Much of the footage never leaves the building, so bandwidth use falls, and the server only stores important footage. It can then serve many more cameras without overloading.

Three-Layer Edge Architecture (from the slides)

Layer	Components	Role
Cloud layer	Cloud server, reached over the Internet	Central storage and heavy, long-term processing
Edge layer	Edge nodes or edge servers, connected by LAN or WAN	Local processing close to the devices
Device layer	Phones, cars, robots, factory machines, sensors, and other IoT devices	Generate and consume the data

A second edge diagram in the slides shows a cloud and data center above an **edge computing platform**. The platform has three functions: real-time data processing with basic analytics, data caching and buffering optimization, and machine-to-machine communication. Edge devices or IoT, such as cameras, sensors, vehicles, drones, and industrial equipment, sit below it.

Cloud Computing vs. Edge Computing

Aspect	Cloud computing	Edge computing
Location	Centralized servers in large data centers, far from the data source	Highly distributed infrastructure, closer to devices and users
Processing	Central cloud server, far from the data source	On-site, fast, and real-time analysis. Does not focus on storing data
Capability	Improved processing and storage capacity. Suited to in-depth, long-term analysis	Lower processing power and storage than the cloud, but better for fast, real-time analysis
Internet dependence	Needs internet connectivity	Can work without internet connectivity
Latency and bandwidth	Connectivity, data movement, bandwidth, and latency costs are relatively high	Lower latency and bandwidth requirements
Suitable for	Applications that are not time-sensitive	Low-latency applications, where every millisecond counts
Operations	Expensive and intensive for the company	Automated scalability with zero-touch provisioning. Lower operational expenses

12. Fog Computing

Fog computing, also called **fog networking**, is a distributed architecture that brings cloud computing capabilities to the edge of a network. Devices can compute, store, and communicate locally, and then route data over the Internet.

Fog computing is a **layer between the edge and the cloud**. When edge devices send huge volumes of data to the cloud, **fog nodes** receive the data and analyze what matters. They forward important data to the cloud for storage. They delete unimportant data, or keep it locally for further analysis. This saves cloud space and moves important data faster.

Where Each Paradigm Processes Data

Paradigm	Where processing happens	Main purpose
Cloud	Central, large-scale data centers	Long-term storage, in-depth analysis, and large-scale processing
Fog	Intermediate nodes between the edge and the cloud	Filter and analyze data, and forward only what matters
Edge	On the device, or on a nearby edge node	Real-time response, low latency, and reduced bandwidth

Memory hook: Edge is at the device. **Fog** is the layer above the edge, a fog bank above the ground. **Cloud** is the top, far-away data center. Data moves up the chain, and only the important parts go all the way to the cloud.

13. Quick Revision Points

- Cloud computing = on-demand, shared, configurable resources over the Internet, with minimal management effort (NIST).
- Five characteristics: on-demand self-service, broad network access, resource pooling, rapid elasticity, measured service.
- Service models: SaaS (applications), PaaS (development platform), IaaS (raw infrastructure). More control as you go down the list from SaaS to IaaS.
- Deployment models: private (one organization), public (shared, pay-per-use), community (shared by a limited group), hybrid (private and public together).
- Edge computing: processing near the device, reducing latency and bandwidth. Fog computing: a layer between the edge and the cloud, filtering data.
- Key drivers: small initial investment, economies of scale, open standards, and sustainability.
- Milestones: 1965 pay-as-you-go on-demand computing model (Corbato et al.). Cloud computing emerged in 2005 to 2006.

Source notes: The slides list "Microsoft Azure Phantom" as a PaaS example, which is probably a typo for Microsoft Azure, so use "Microsoft Azure" in your answer. The Cisco Metapod name is also as written in the slides. The characteristics, service model overview, and "Traditional IT vs Cloud" sections include image-only slides. This summary covers their text and the edge diagrams. Check those slides directly for any extra detail. The GCP classification noted in Section 7 is also worth confirming.

Cloud Security Issues and Cybersecurity

Class 5 Notes: Cloud Challenges, Eleven Leading Threats, Component-Based Attacks, Public Cloud Incidents

Class outline: the challenges of cloud computing, why cloud security is a major concern, the Cloud Security Alliance threat list, protection mechanisms, attacks grouped by cloud component (network, virtual machines, storage, applications), and major public cloud incidents. Exam questions often ask you to name a threat, describe its attack path, and give a protection mechanism.

PART A: CLOUD CHALLENGES AND THREATS

1. Challenges of Cloud Computing

Like any new technology, cloud adoption brings problems. The slides list nine important challenges:

#	Challenge	Key point
1	Security and privacy	Valuable enterprise data sits outside the corporate firewall. An attack on one site can affect many clients.
2	Interoperability and portability	No industry standards for APIs, cloud interfaces, or interoperability. Moving services between providers, or between public and private clouds, is hard.
3	Reliability and availability	Outages at major providers are well documented. Cloud computing is trust-based, and lack of trust slows adoption.
4	Performance and bandwidth cost	Hardware savings can be offset by bandwidth costs. Performance questions can arise even in well-designed clouds.
5	SLA and service quality	Clients fear providers do not guarantee application security, even when an SLA exists. Quality of service remains an open research area.
6	Lack of skill, knowledge, and expertise	Many organizations lack staff and tools to use cloud technology properly. A cloud skills gap still exists.
7	Recovery and loss of data	Data loss threatens customer trust, so a proper backup and recovery policy is essential.
8	Insecure APIs	APIs connect users to cloud services. Insecure APIs let attackers expose data, take over accounts, and disrupt services.
9	Vendor lock-in	Customers depend on one provider's technology and cannot switch without major cost, legal, or technical barriers.

Other Issues Raised in the Slides

- Customer data and programs both reside on the cloud provider's premises.
- **Loss of control** over data, infrastructure, and security policy.
- **Lack of trust**, particularly in the service level agreement.
- **Multi-tenancy**, where many customers share the same infrastructure.
- **Lack of visibility** into the environment.

Quote from the slides (paraphrased): former Cisco CEO John Chambers said cloud computing is a security nightmare that cannot be handled in traditional ways.

2. Why Cloud Security Is a Major Concern

Security is always a major concern in open system architectures. In cloud computing, customer data and code reside on the provider's premises, not on the customer's own network. Traditional security mainly means keeping bad actors out. In the cloud, an attacker must either compromise the authentication and access control system or impersonate an existing user.

Three Sources of Cloud Security Problems

Source	What it means
Loss of control	Data, applications, and resources sit with the provider. The provider manages user identity, access control rules, security policies, and enforcement. The consumer relies on the provider for data security and privacy, resource availability, and monitoring and repair of services.
Lack of trust	Consumers need mechanisms to trust the provider. Service Level Agreements (SLAs) formally define the level of service, priorities, responsibilities, guarantees, and warranties. The slides argue for a layer that supports contract negotiation and monitors contract enforcement.
Multi-tenancy	Independent users share the same physical infrastructure. An attacker can legitimately be on the same physical machine as the target.

Lack of Visibility

A typical cloud environment mixes IaaS, SaaS, and PaaS components, often with on-premises data centers in hybrid models. Third-party applications, digital identities, and sensitive data multiply quickly, leading to **cloud sprawl**, where the organization loses control of its cloud resources. Without full visibility, incident response slows, which lets a breach persist and cause greater financial and reputational damage. The slides use the Target breach as the example.

3. The Eleven Leading Cloud Security Threats

The slides and the report cite the **Cloud Security Alliance (CSA) 2026 report**, which identifies eleven leading cloud security threats based on industry surveys. Inadequate Identity and Access Management ranks first. The report also flags AI-enhanced attacks and AI system compromise as newly prominent concerns.

No.	Threat	Risk level (where given)
1	Cloud misconfiguration	High
2	Identity and Access Management (IAM) attacks	Critical
3	Insecure APIs and interfaces	Not rated
4	Data breaches and unauthorized data access	Critical
5	Account hijacking and credential theft	Not rated
6	Cloud ransomware attacks	Not rated
7	Distributed Denial of Service (DDoS)	Not rated
8	Insider threats	Not rated
9	Insecure virtualization and hypervisor vulnerabilities	Not rated
10	Supply chain attacks	Not rated
11	Advanced Persistent Threats (APTs)	Not rated

Note: the slides say a security issue is anything that happens to an asset, including attacks, misconfiguration, faults, damage, loopholes, and weaknesses in the system.

4. Threat Details: Attacks and Protection

4.1 Cloud Misconfiguration (High risk)

Misconfiguration is one of the most common causes of cloud incidents. Examples: publicly accessible storage buckets, databases exposed to the internet, incorrect firewall or security group rules, unprotected virtual machines, incorrect access permissions, exposed admin interfaces, and insecure default settings.

Example attack: research data is stored in cloud storage, and the bucket is accidentally made public. An attacker finds it and downloads the files. The cloud provider itself is not compromised. The customer's configuration is the weak point.

Protection: Cloud Security Posture Management (CSPM), automated configuration auditing, Infrastructure as Code (IaC) security scanning, continuous compliance monitoring, and automated remediation of dangerous configurations.

4.2 Identity and Access Management (IAM) Attacks (Critical risk)

IAM controls who can access cloud resources and what they can do. Attackers target user credentials, administrator accounts, API keys, access tokens, and service accounts. Major vulnerabilities: weak passwords, no MFA, stolen credentials, excessive privileges, poorly managed service accounts, compromised API keys, privilege escalation, and session hijacking or token theft.

Example: an attacker phishes a cloud administrator's credentials, logs into the cloud console, and reaches virtual machines, databases, and storage.

Protection: MFA, Role-Based Access Control (RBAC), Attribute-Based Access Control (ABAC), Privileged Access Management (PAM), identity federation, short-lived access tokens, continuous identity monitoring, and Zero Trust Architecture (ZTA). The key principle is **least privilege**: users get only the permissions their role requires.

4.3 Insecure APIs and Interfaces

Cloud environments rely heavily on APIs to connect applications, databases, virtual machines, storage, and management services. An insecure API gives attackers an entry point into the infrastructure. Common flaws: broken authentication and authorization, API key exposure, excessive data exposure, injection, weak input validation, unrestricted access, and rate-limit bypass.

Example: a university API returns student records. Because it does not check authorization, an attacker changes the student ID in the request and reads another student's personal data. This is an **insecure direct object reference** pattern.

Protection: API gateway, Web Application Firewall (WAF), OAuth 2.0 and OpenID Connect, mutual TLS (mTLS), strict authentication and authorization, rate limiting, input validation, and API security testing.

4.4 Data Breaches and Unauthorized Data Access (Critical risk)

A cloud data breach happens when an unauthorized party reaches confidential data. Cloud databases hold personal identification data, financial and medical records, government records, research data, intellectual property, and authentication credentials. Attack paths: stolen credentials, SQL injection, misconfigured storage, insiders, vulnerable applications, and compromised third-party services.

Mechanism	Purpose
AES-256 encryption	Protects data at rest
TLS 1.3	Protects data in transit
Database encryption	Protects database contents
Tokenization	Replaces sensitive values with tokens
Data Loss Prevention (DLP)	Detects and prevents unauthorized data transfers

Mechanism	Purpose
Data access governance	Controls access to sensitive data
Data classification	Identifies levels of sensitivity

4.5 Account Hijacking and Credential Theft

Account hijacking means an attacker takes control of a legitimate cloud account. Techniques: phishing, credential stuffing, brute force, password spraying, session cookie theft, OAuth token theft, and malware that harvests credentials. Consequences: unauthorized access, data theft, creation of rogue virtual machines, changes to security settings, ransomware installation, and financial loss from unauthorized resource use.

Protection: phishing-resistant MFA, passwordless authentication, conditional access policies, continuous session validation, detection of unusual login locations and devices, and automatic account suspension after suspicious activity.

4.6 Cloud Ransomware

Ransomware encrypts files or otherwise makes data unavailable, and demands payment for recovery. In the cloud it can enter through: compromised administrator accounts, infected VMs, endpoints that sync with cloud storage, exploited application flaws, compromised backup accounts, and abuse of storage APIs.

Typical attack lifecycle: initial compromise (phishing, stolen credentials, or a vulnerable application), then privilege escalation, lateral movement, data exfiltration and encryption, and finally extortion and service disruption.

Protection: immutable and offline backups, Endpoint Detection and Response (EDR), network segmentation, protection of privileged accounts, ransomware behaviour detection, recovery testing, and separate administration accounts for backups.

4.7 Distributed Denial of Service (DDoS)

DDoS attacks make cloud services unavailable by overwhelming them with malicious traffic or requests.

DDoS type	Mechanism
Volumetric	Floods networks with massive traffic
Protocol-based	Exploits weaknesses in network protocols
Application-layer	Overloads HTTP, DNS, or application services
DNS amplification	Uses DNS infrastructure to amplify traffic
HTTP flood	Sends excessive HTTP requests

Consequences: website unavailability, disrupted online education, failed financial transactions, service degradation, and higher cloud bills. **Protection:** cloud DDoS protection services, WAF, rate limiting, traffic filtering, Content Delivery Network (CDN), auto-scaling with spending controls, and network anomaly detection.

4.8 Insider Threats

Insiders already have legitimate access, and may be employees, system administrators, database administrators, developers, contractors, or third-party service staff. Three types:

- **Malicious insider:** deliberately steals or destroys information.
- **Negligent insider:** accidentally exposes confidential data.
- **Compromised insider:** an employee's account is taken over by an attacker.

Example: a cloud administrator downloads confidential research data and moves it to an external storage account. **Protection:** User Behaviour Analytics (UBA), PAM, DLP, separation of duties, audit trails, continuous access monitoring, and regular access reviews.

4.9 Insecure Virtualization and Hypervisor Vulnerabilities

Many virtual machines run on one physical server. The **hypervisor** manages physical resources and isolates the VMs. A flaw in the hypervisor can break that isolation. Threats: hypervisor exploitation, **VM escape** (an attacker in a VM crosses the isolation boundary to reach the hypervisor or host), VM-to-VM attacks, insecure VM images, VM sprawl, snapshot theft, unauthorized VM cloning, and side-channel attacks.

Protection: hypervisor patching, strong VM isolation, secure VM images, hardware-assisted virtualization security, VM integrity monitoring, and network micro-segmentation.

4.10 Supply Chain Attacks

Cloud services depend on third-party software libraries, APIs, plugins, development tools, managed services, and vendors. An attacker who compromises one of these components can use it as an entry point. Examples: malicious software packages, compromised CI/CD pipelines, vulnerable third-party libraries, compromised software updates, exposed vendor credentials, and insecure managed-service integrations.

Protection: Software Bill of Materials (SBOM), Software Composition Analysis (SCA), dependency vulnerability scanning, secure CI/CD pipelines, vendor security assessments, code signing, and restricted third-party access.

4.11 Advanced Persistent Threats (APTs)

APTs are sophisticated attacks in which threat actors keep unauthorized access to a system for a long time. Cloud infrastructure is an attractive target for espionage, intellectual property theft, and strategic intelligence. Typical activities: initial compromise through phishing, credential theft, privilege escalation, lateral movement, persistence through cloud identities, data exfiltration, and concealment of activity.

Protection: threat intelligence, Security Information and Event Management (SIEM), Extended Detection and Response (XDR), EDR, Cloud Detection and Response (CDR), behavioural analytics, and threat hunting.

5. Additional Threats from the Detailed Report

The longer report adds several threats beyond the eleven, along with their protection mechanisms:

Threat	Description	Protection
Lack of visibility and logging	Incomplete audit logs, unmonitored resources, inconsistent log retention, and delayed detection	Centralized logging, SIEM, cloud-native audit logs, continuous monitoring, alerts
Cryptojacking	Attackers secretly use cloud compute to mine cryptocurrency. Results in higher bills and slower performance	CPU and GPU monitoring, cost anomaly detection, runtime malware detection, resource quotas
Container vulnerabilities	Weak images or runtime configurations in containerized workloads	Image scanning, runtime security
AI-enhanced phishing and vulnerability discovery	AI helps attackers write convincing phishing and find weaknesses faster	AI security monitoring and guardrails
Prompt injection	Manipulation of cloud-hosted LLM applications	Prompt injection protection, runtime guardrails
Data poisoning	Manipulation of training data to corrupt model behaviour	Training data validation
Model theft and model extraction	Unauthorized copying of proprietary models, or rebuilding their behaviour through queries	AI model access control, secure model registries
Model supply chain attacks	Compromise of model dependencies or artifacts	Model integrity verification
AI agent compromise	Abuse of an agent's permissions, tools, or credentials	Human approval for sensitive agent actions
Training data leakage	Exposure of confidential training information	AI activity monitoring

6. Summary: Threats and Major Security Solutions

No.	Cybersecurity issue	Major security solution
1	Cloud misconfiguration	CSPM
2	IAM attacks	MFA, RBAC, Zero Trust Architecture
3	Insecure APIs	API gateway, WAF
4	Data breaches	Encryption, DLP
5	Account hijacking	MFA, UEBA
6	Ransomware	EDR, immutable backup
7	DDoS	CDN, DDoS protection
8	Insider threats	PAM, UEBA
9	Hypervisor attacks	Hypervisor hardening
10	Container vulnerabilities	Image scanning, runtime security
11	Supply chain attacks	SBOM, SCA
12	APTs	SIEM, XDR, threat intelligence
13	Lack of visibility	Centralized logging, SIEM
14	Cryptojacking	Cost and resource anomaly detection
15	AI-related attacks	AI security monitoring and guardrails

UEBA = User and Entity Behaviour Analytics. PAM = Privileged Access Management. CDN = Content Delivery Network. SBOM = Software Bill of Materials. SCA = Software Composition Analysis.

PART B: ATTACKS BY CLOUD COMPONENT AND PUBLIC CLOUD INCIDENTS

7. Attacks Based on Cloud Components

For comparative analysis, the slides group cloud attacks by the component they target. There are four categories, labeled A1 to A4.

Component	Attacks
A1: Network	Port scanning; botnets; spoofing attacks. These can degrade service quality and put data privacy and confidentiality at risk.
A2: Virtual machines	Cross-VM side-channel attacks; VM creation attacks; VM migration and rollback attacks; VM scheduler attacks. Several VMs on one host create several security risks.
A3: Storage	Data scavenging (searching data residue to find sensitive information); data reduplication (removing duplicate copies, which can be abused). An outsider or malicious insider can steal private data, and manipulation is easy without strict monitoring.
A4: Applications	Malware injection attacks (injecting code to trace execution paths and exploit them); shared architecture attacks; web services and protocol-based attacks.

Definitions to Know

- **Data scavenging:** searching a system's data residue to gain unauthorized access to sensitive or valuable information.
- **Data reduplication:** a technique that removes duplicate copies of data to save storage. It is also a risk area when the process is abused.
- **Cross-VM side-channel attack:** one VM infers information about another VM on the same host, through shared hardware behaviour, such as timing.

8. Major Public Cloud Cybersecurity Incidents

Public cloud platforms (AWS, Microsoft Azure, and Google Cloud Platform) run critical infrastructure for governments, banks, universities, healthcare providers, and large businesses. Incidents show that **a breach in a customer's cloud environment does not necessarily mean the provider's infrastructure was compromised**. Attackers often exploit customer-side misconfigurations, stolen credentials, vulnerable applications, or weak access policies.

8.1 Capital One Cloud Data Breach (USA, 2019): AWS

- About **106 million** individuals in the USA and Canada were affected. Exposed data included names and addresses, credit scores, credit card application information, and Social Security numbers for some people.
- **Attack chain:** an application-layer flaw, a server-side request forgery (SSRF) vulnerability linked to a web application firewall configuration, access to the AWS instance metadata service, temporary AWS credentials, excessive permissions, then download of customer data.
- **Lessons:** configure IAM permissions properly, protect instance metadata, apply least privilege, monitor storage access continuously, and assess applications for security.

8.2 Microsoft Cloud Identity Compromise: Storm-0558 (Global, 2023 to 2024)

- The campaign affected Microsoft customer email accounts, including US government and other organizations, through Exchange Online.
- **Attack chain:** theft of a Microsoft signing key, forging of authentication tokens, abuse of cloud identity authentication, then unauthorized access to email.
- **Lessons:** protect cryptographic signing keys, strengthen cloud identity architecture, monitor tokens, improve logging, and control privileged infrastructure strictly.

8.3 Snowflake Customer Data Breaches (Global, 2024)

- Attackers used stolen credentials to enter many customer Snowflake environments. Some accounts did not have MFA enabled.
- Affected organizations included Ticketmaster and Santander Bank. Stolen data was used in extortion.
- **Lessons:** enforce MFA, monitor unusual logins, rotate exposed credentials, apply network access policies, and watch for bulk data extraction.

8.4 Microsoft Midnight Blizzard Cloud Email Compromise (USA, 2024)

- Microsoft disclosed that Midnight Blizzard, a Russian state-sponsored actor, had accessed some corporate email accounts.
- **Attack chain:** password spraying against a legacy, non-production test tenant, then abuse of an OAuth application to reach more corporate email.
- **Lessons:** secure legacy and test environments, monitor password spraying, audit OAuth application permissions, enforce MFA and privileged access controls, and investigate suspicious identity activity.

8.5 European Commission AWS Breach (Europe, March 2026)

- The compromise affected the europa.eu public website hosting platform. About **91.7 GB** of compressed data was exfiltrated, including personal and email-related information. Data for other EU entities may also have been affected.

- **Attack chain:** a compromised version of the Trivy security scanning tool entered the software supply chain, attackers harvested an AWS secret from the environment, used it to access the AWS account, performed reconnaissance, created more access credentials, and exfiltrated data.
- **Lessons:** secure development pipelines, protect secrets and API keys, use short-lived cloud credentials, monitor AWS API activity, use SBOMs and dependency verification. A compromised **security tool** became the route into a major cloud environment.

8.6 Retool Cloud Application Compromise (USA, 2023)

- Attackers used sophisticated SMS phishing to compromise employee accounts, then bypassed the organization's MFA by exploiting weaknesses in the authentication process. They gained access to internal systems and some cloud customer environments.
- **Lessons:** use phishing-resistant MFA, protect identity systems, monitor suspicious authentication changes, restrict production access, and secure sessions and devices.

8.7 Football Australia AWS Data Exposure (Australia, 2024)

- Exposed AWS credentials raised concerns about access to cloud storage and sensitive organizational data. The incident highlighted weak access-key management and weak monitoring.
- **Lessons:** never place AWS access keys in source code, rotate compromised credentials, use IAM roles instead of long-lived keys, and monitor S3 and other resource access.

8.8 Toyota Cloud Data Exposure (Japan, 2023)

- Vehicle-related customer information was publicly accessible for an extended period because of cloud configuration errors. Some data could have been accessed by unauthorized parties.
- **Lessons:** audit configurations continuously, restrict public storage access, monitor permission changes, and automate cloud security posture management.

8.9 Microsoft Azure Service Disruption (USA, 18 July 2024)

- An Azure infrastructure incident affected virtual machine access in the Central US region for about half a day. Some enterprise customers could not reach their services.
- The slides note this was an infrastructure disruption, **not a confirmed malicious attack**. The lesson is that cloud security must cover availability and resilience, not only confidentiality and integrity.

8.10 CrowdStrike Global IT Outage (Worldwide, 19 July 2024)

- A defective CrowdStrike Falcon software update crashed Windows systems. About **8.5 million** Windows devices were affected, and aviation, banking, healthcare, and retail were disrupted.
- **Important distinction:** this was **not a cloud data breach or a cyberattack**. It was a defective security update with a worldwide operational impact. It shows the systemic risk of centralized, cloud-connected security ecosystems.

8.11 Other Significant Incidents

Incident	Year	Environment	Main issue
Uber data breach	2016	AWS-related infrastructure	Exposed credentials and unauthorized access
Code Spaces attack	2014	AWS	Attacker took control of the AWS management console, deleted resources, and the company ceased operations
Accenture cloud storage exposure	2017	AWS S3	Publicly exposed storage holding credentials and internal data
Microsoft Cosmos DB (ChaosDB)	2021	Azure	Vulnerability in the Jupyter Notebook feature could expose database credentials. Microsoft remediated it

Incident	Year	Environment	Main issue
DarkBeam data exposure	2023	Cloud-hosted Elasticsearch	Unsecured database
Sumo Logic AWS incident	2023	AWS	Unauthorized access to an AWS account. Customers were told to rotate secrets

8.12 Comparative Overview of Major Incidents

Incident	Year	Provider	Primary attack type
Code Spaces	2014	AWS	Account compromise and destructive attack
Accenture	2017	AWS	Public storage exposure
Capital One	2019	AWS	SSRF and IAM exploitation
ChaosDB	2021	Azure	Cloud database vulnerability
Toyota	2023	Cloud environment	Misconfiguration
Storm-0558	2023	Microsoft cloud	Authentication token forgery
Retool	2023	Google Cloud-related services	Spear phishing and MFA compromise
Midnight Blizzard	2024	Microsoft cloud	Password spraying and OAuth abuse
Snowflake	2024	Snowflake	Stolen credentials
CrowdStrike outage	2024	Cloud-connected security ecosystem	Defective software update
European Commission	2026	AWS	Software supply chain compromise

9. Five Key Lessons from the Incidents

- **Identity compromise:** stolen credentials, weak MFA, and compromised tokens are major attack paths.
- **Cloud misconfiguration:** public storage and wrong access permissions can expose huge volumes of data.
- **Supply chain vulnerabilities:** a compromised development or security tool can give access to cloud infrastructure.
- **Insufficient monitoring:** organizations must watch API calls, administrator activity, unusual data transfers, and access-key creation.
- **Dependency and resilience:** even with no attacker, a faulty update or infrastructure failure can disrupt critical services worldwide.

10. Conclusion

Cloud computing has opened new possibilities for compute, storage, access, flexibility, productivity, and economies of scale. It has also created new security concerns for users, IT staff, enterprises, and individuals. Understanding these challenges and threats lets an organization's IT team build a **multi-cloud security strategy** to protect the company's data and services.

11. Quick Revision Points

- Nine challenges include security and privacy, interoperability and portability, reliability, SLA, skills, data recovery, insecure APIs, and vendor lock-in.
- Three sources of cloud security problems: loss of control, lack of trust, and multi-tenancy.
- The CSA 2026 report lists eleven leading threats. IAM ranks first.
- Misconfiguration is the most common cause. Protect it with CSPM and automated audits.

- Least privilege, MFA, and Zero Trust are the main answers to IAM and account attacks.
- Insecure APIs are fixed with an API gateway, WAF, OAuth 2.0, input validation, and rate limiting.
- Ransomware defence: immutable backups, EDR, and network segmentation. DDoS defence: CDN, WAF, rate limiting, and auto-scaling with spending limits.
- Hypervisor attack = VM escape, which breaks VM isolation. Supply chain attack = a compromised third-party component. APT = long-term hidden access.
- Component attacks: A1 Network, A2 Virtual machines, A3 Storage, A4 Applications.
- Know Capital One (2019, SSRF to metadata to credentials, about 106 million people), Storm-0558 (signing key theft, forged tokens), Snowflake (no MFA), Midnight Blizzard (password spraying and OAuth), European Commission (Trivy supply chain, 91.7 GB), and CrowdStrike (not a breach, 8.5 million devices).

Source notes: The report describes the Retool compromise (2023) under a Google Cloud-hosted heading, and its comparative table lists Retool under Google Cloud-related services. A separate report section on third-party services covers Sumo Logic. The slides do not cover Retool, so confirm the details before the exam. The CSA 2026 report and the incident figures (106 million, 91.7 GB, 8.5 million devices) are as the sources report them, so verify them against the original reports. The CrowdStrike incident was a defective update, not a cloud data breach, so keep it separate in exam answers.